

Ataki Evil Twin, KARMA i MANA

Analiza, detekcja i przeciwdziałanie

Bezpieczeństwo Sieci Bezprzewodowych

Agenda

Ataki

1. **Evil Twin** – klonowanie SSID, deauth, captive portal
2. **KARMA** – pasywne przechwytywanie probe requestów
3. **MANA** – zaawansowany (directed probes + loud mode)

Detekcja

4. Metoda 1: **Fingerprinting IE**
5. Metoda 2: **Analiza RSSI**
6. Metoda 3: **Sequence Numbers**

Wyniki praktyczne

7. Środowisko laboratoryjne
8. **Eksperyment: 10 cykli ON/OFF**
9. Porównanie metod ataku
10. Wnioski i mitygacja

Atak 1: Evil Twin

Mechanizm

1. Klonujemy **konkretny SSID** (np. 601A)
2. Wysyłamy **ramki deauth** do klientów
3. Klient traci połączenie z oryginałem
4. Klient łączy się z **naszym AP** (silniejszy sygnał)
5. Captive portal → **przechwytujemy hasło**

Nasz setup

Komponent	Specyfikacja
Karta atakującego	TP-Link TL-WDN3200 (RT5572)
Oryginalny AP	Router domowy 601A



Nasze wyniki

Eksperyment: 10 cykli ON/OFF

- 🟢 Evil Twin AP: 64:70:02:18:B9:22
- 🟡 Oryginalny AP: 7C:F1:7E:C1:7B:95
- 📦 55 490 pakietów przechwyconych
- 📡 6 810 beaconów (2 928 Evil Twin + 3 882 oryginał)



iPhone przechodził między AP przez 10 cykli!

Atak 2: KARMA

Karma Attacks Radio Machines Automatically

1. Rogue AP **nasłuchuje** probe requestów
2. Każdy klient wysyła zapytania o znane sieci
3. KARMA odpowiada beaconem z **żądanym SSID**
4. Klient łączy się automatycznie

Kluczowa różnica

Evil Twin

- Celuje w 1 **konkretny SSID**
- Używa **deauth**
- Wiele BSSID → 1 SSID

KARMA

- Łapie **wszystkie SSID**
- **Bez deauth**
- 1 BSSID → **wiele SSID**

Nasze wyniki

hostapd-mana (enable_mana=0)

Przechwycone probe requesty iPhone'a:

```
Probe Request (601A) -34 dBm
Probe Request (601A) -34 dBm
Probe Request (601A) -40 dBm
```

iPhone aktywnie szuka sieci 601A – KARMA przechwytuje

Uwaga: KARMA **nie wymusza** rozłączenia. Klient sam decyduje czy się połączyć. Nowe iOS (10+) używają pasywnego skanowania – mniej probe requestów.

Atak 3: MANA

SensePost, Defcon 22

MANA = KARMA na sterydach:

- ✅ Odpowiada na **directed probe requests** (ignoruje docelowy BSSID)
- ✅ **Loud Mode** – emituje popularne SSID co ~10s
- ✅ **EAP Capture** – przechwytuje handshake dla sieci Enterprise
- ✅ **Multiple BSSID** – jeden interfejs → wiele wirtualnych AP

Dlaczego MANA nas "nie rozłączyła"?

MANA to atak **pasywny** – czeka aż klient przyjdzie, nie wyrzuca go z sieci. Evil Twin używa **deauth** do siłowego przełączenia.

Nasze wyniki

hostapd-mana (enable_mana=1)

```
MANA - Directed probe request
      for SSID '601A'
      from ba:a1:0e:08:e0:35
```

✅ **MANA przechwycił directed probe requesty iPhone'a!**

Metryka	Evil Twin	KARMA	MANA
Deauth	✅	❌	❌
Cel	1 SSID	Wszystkie	Wszystkie + Loud
Skuteczność	Wysoka	Średnia	Bardzo wysoka

Metody detekcji – przegląd



Metoda 1

Fingerprinting IE

Porównanie Information
Elements w ramach Beacon

15/18 IE

różniących się

HT Capabilities
Vendor Specific (OUI)
Power Constraint
Extended Capabilities



Metoda 2

Analiza RSSI

Monitorowanie poziomu
sygnału

Δ 20.3 dBm

różnicy

Evil Twin: -22.3 dBm
Oryginał: -42.6 dBm
Anomalia!



Metoda 3

Sequence Numbers

Śledzenie numerów
sekwencyjnych

2 strumienie

niezależne

Evil Twin: 0–2045
Oryginał: 0–4095
Brak nakładania!

● WERDYKT: EVIL TWIN POTWIERDZONY wszystkimi trzema metodami

An error occurred on this slide. Check the terminal for more information.

An error occurred on this slide. Check the terminal for more information.

Eksperyment: 10 cykli ON/OFF Evil Twin

Przed wyłączeniem

iPhone na **Evil Twin**

64:70:02:18:B9:22

iPhone ← Evil Twin

RSSI: -29 dBm

Szybkość: 54 Mbps

Po wyłączeniu AP

iPhone **bez Wi-Fi**

(przez ~5 sekund)

iPhone odłączony

Szuka sieci...

Probe requests: 601A

Po włączeniu AP

iPhone **wraca** na Evil Twin

iPhone → Evil Twin

Nowy seq#: od 0

DHCP: nowy adres IP

Statystyki z 10 cykli

Metryka

Wartość

Pakiety łącznie

55 490

Beacony Evil Twin

2 928

TLS SNI – podsłuchiwanie domen

Nawet z szyfrowanym DNS!

- iPhone używa **DNS-over-HTTPS** (port 53 pusty)
- Ale **TLS Client Hello** zawiera **SNI** (Server Name Indication)
- SNI zdradza nazwę domeny – **nie da się tego ukryć**

Przechwycone domeny

```
setup.icloud.com  
smp-device-content.apple.com  
p17-buy.itunes.apple.com
```

Nawet przy zaszyfrowanym DNS i HTTPS, widać jakie domeny odwiedza iPhone!

Łamanie WPA Handshake PMKID Attack

```
hashcat -m 22000 handshake.hc22000
```

Wynik: Hasło złamane!

```
nbi8-yhs5-ajxp
```

- ✓ PMKID przechwycony z Evil Twin AP
- ✓ Hashcat odzyskał hasło w < 30 sekund
- ✓ Dowód: cały łańcuch ataku działa

Porównanie trzech ataków

Cecha	Evil Twin	KARMA	MANA
Mechanizm	Klonowanie SSID + deauth	Odpowiada na probe requesty	Directed probes + Loud Mode
Wymusza rozłączenie?	✅ Tak (deauth)	❌ Nie	❌ Nie
Zna SSID ofiary?	✅ Tak	❌ Nie	❌ Nie
BSSID	Wiele → 1 SSID	1 → wiele SSID	1 → wiele SSID
Wykrywanie	Duplikat SSID	Anomalia: 1 BSSID wiele SSID	Loud beacons
Skuteczność	★★★★ Wysoka	★★★ Średnia	★★★★ Bardzo wysoka

Mitygacja – jak się bronić?

Dla administratorów sieci

- **802.11w (PMF)** – Protected Management Frames
Szyfruje ramki zarządzania → blokuje deauth
- **WIDS/WIPS** – systemy detekcji
Monitorują duplikaty SSID, anomalie RSSI
- **EAP-TLS** – certyfikaty dla AP
Klient weryfikuje tożsamość AP

Dla użytkowników

- **VPN** – szyfruje ruch
Nawet na rogue AP, dane są bezpieczne
- **Unikanie otwartych sieci** Publiczne Wi-Fi to łatwy cel
- **Sprawdzanie certyfikatów HTTPS** Zielona kłódka ≠ bezpieczne Wi-Fi
- **Wyłączanie auto-join** Nie łącz się automatycznie z "znanymi" sieciami

Nasze narzędzia jako lekki WIDS

Podsumowanie

● Przeprowadzone ataki

3

Evil Twin · KARMA · MANA

🛡️ Metody detekcji

3

IE · RSSI · Seq Numbers

📊 Dane
eksperymentalne

55k+

pakietów w 10 cyklach

Kluczowe wnioski

1. **Wszystkie 3 ataki** zostały przeprowadzone i udokumentowane w kontrolowanym środowisku
2. **Każdy atak** jest wykrywalny przez analizę ramek Beacon
3. **Najskuteczniejsza detekcja** = połączenie 3 metod (IE + RSSI + Seq#)
4. **802.11w (PMF)** skutecznie blokuje deauth, ale nie zapobiega Evil Twin
5. **Opracowane narzędzia** (analyzer_pcap.py, beacon_diff.py) są dostępne jako open source

Dziękujemy za uwagę!

Pytania?

Repozytorium: github.com/Hose-Zur/BBSK-Evil-Twin

Narzędzia: `analyzer_pcap.py` · `beacon_diff.py` · `generate_report.py`

Dokumentacja: `PLAN_PRAKTYCZNY.md` · `NARZEDZIA.md` · `BIBLIOGRAFIA.md`